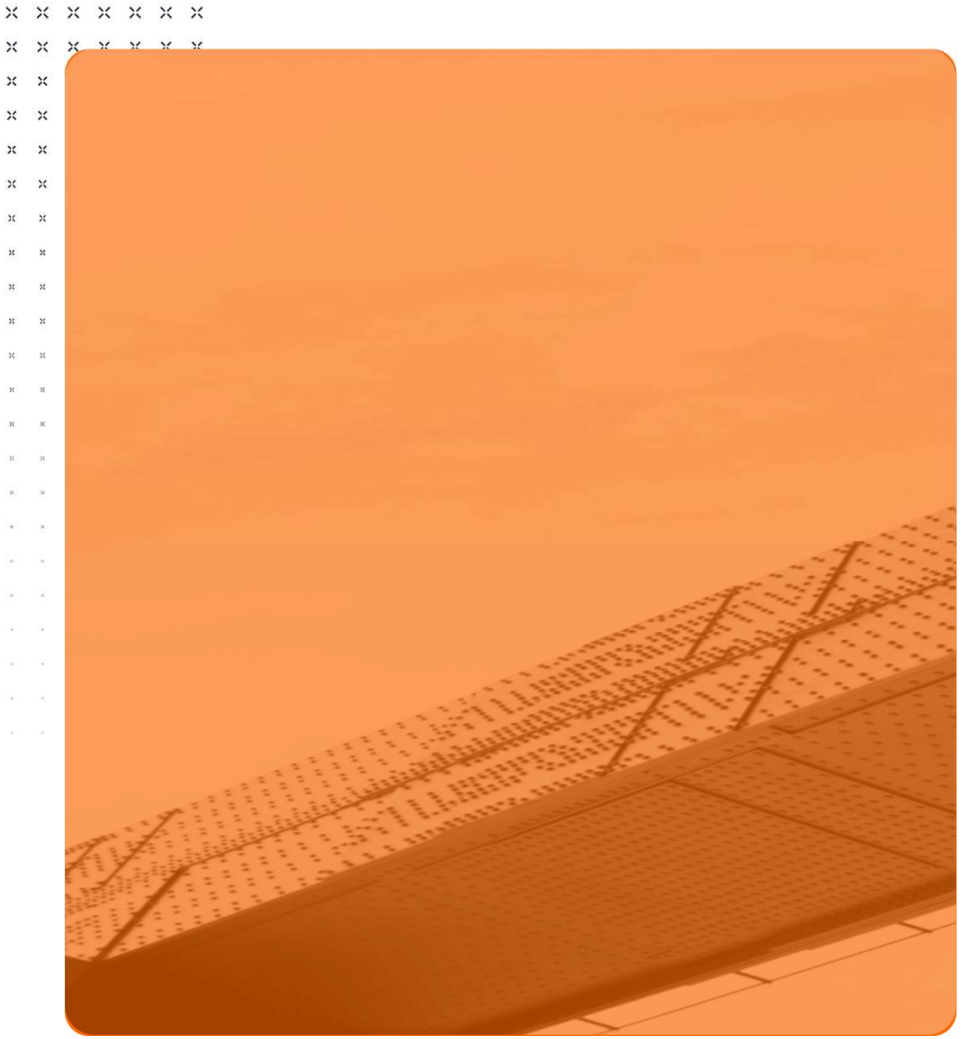
DRAWBRIDGE

GenAI Security Assessments: ChatGPT & Claude

WHY THIS MATTERS NOW

- AI adoption is accelerating faster than governance and security.
- Most firms are already integrated AI into their workflows.
- These new assessments help clients answer:
  - “Are we using AI safely, defensibly, and in a way that minimizes business risk?”



WHAT WE'RE LAUNCHING

Two new, parallel offerings:

- ChatGPT Security Assessment
- Claude Security Assessment
  - Gemini is in progress but not available yet

Both are expert-led, point-in-time security and governance configuration reviews of how the organization is using the AI platform. These are meant to lead to:

- Alignment with other Drawbridge services
- Better visibility into the firm's risk profile
- Recurring audits

"This is a structured audit of AI security controls and governance—focused on preventing data leakage, misuse, and compliance gaps."

REQUIREMENTS:

- -An enterprise version of the AI tool being audited.
- -An AI tool administrator who has access to all security configurations.
- -Dedicated time to perform a screenshare with the client.

WHO IS THIS IS FOR

- Clients who are already using ChatGPT Enterprise or Claude Enterprise
- Firms concerned with investor or regulatory requirements related to cybersecurity.
- Organizations handling sensitive or confidential data.
- Leadership asking for AI policies, guardrails, or oversight.

Common trigger events

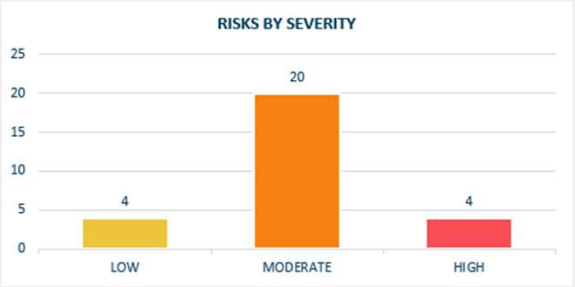
- "We want to scale AI, but don't know our risk exposure"
- Employees using AI without clear rules (shadow AI)
- Investor, board, or regulator questions about AI use
- Security or compliance teams being asked to "sign off" on AI

WHAT WE ACTUALLY DO

- Discovery & current-state review
  - Identify how AI is being used across teams
  - Review access controls and authentication
  - Understand governance, policies, and training coverage
- Platform-specific control audit
  - Identity & access management
  - Data protection and privacy
  - Sharing and collaboration settings
  - Integrations and connectors
  - Configuration hardening
  - AI feature and capability risks
  - Governance, training, and oversight
- Risk findings & remediation roadmap
  - Clear, prioritized findings (high / moderate / low)
  - Practical remediation guidance
  - Quick wins vs longer-term improvements
  - Clear next steps (policy, training, TTX, etc.)

SUMMARY

The graph below displays the breakdown of High, Moderate, and Low severity risks Drawbridge identified during the assessment. In addition to risk ratings, recommendations for mitigating or remediating the risks are available for guidance.



RISKS IDENTIFIED

IDENTITY & ACCESS MANAGEMENT			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Single Sign-On (SSO) is not configured.	Without SSO, user access may persist after termination, credentials may be weak or reused, and access cannot be centrally revoked. This significantly increases the risk of unauthorized access to sensitive prompts, files, and GPT configurations.	Enforce SSO for all users through the corporate IdP and disable local ChatGPT passwords. Validate that all active users are federated identities.
MODERATE	SCIM is not used to provision and deprovision user accounts.	Manual user management can result in orphaned accounts, delayed deprovisioning, and inconsistent role assignments. Former employees retaining access pose a significant insider risk.	Enable SCIM provisioning and validate that user lifecycle events are automatically reflected in ChatGPT. Periodically reconcile users against HR records.
Security Controls Currently in Place			
• Role-Based Access Control (RBAC) is in use. • Administrative access is limited to two to three accounts.			

REAL-WORLD EXAMPLES

- AI access to sensitive data magnifies existing permission issues. This give employees to data they shouldn’t be accessing.
- Teams are allowed to share prompts, GPTs, or sessions publicly without realizing it.
- Developers or power users are enabling advanced AI features without training or guardrails.
- Most incident response plans and tabletop exercises don’t account for AI misuse scenarios.

Clients are usually surprised by what settings are turned on by default.

Positioning and Discovery

This is:

- A proactive AI security audit, not a reaction to an incident
- A governance and compliance readiness exercise
- A way to enable safe AI adoption, not slow it down
- A fast, high-value engagement that opens the door to more work

Core message:
"This helps you innovate with AI while staying aligned with security, investor, and regulatory requirements. AI usage significantly increases the firm's attack surface, and these exercises aim to mitigate reputational and financial damage due to a weak AI security program"

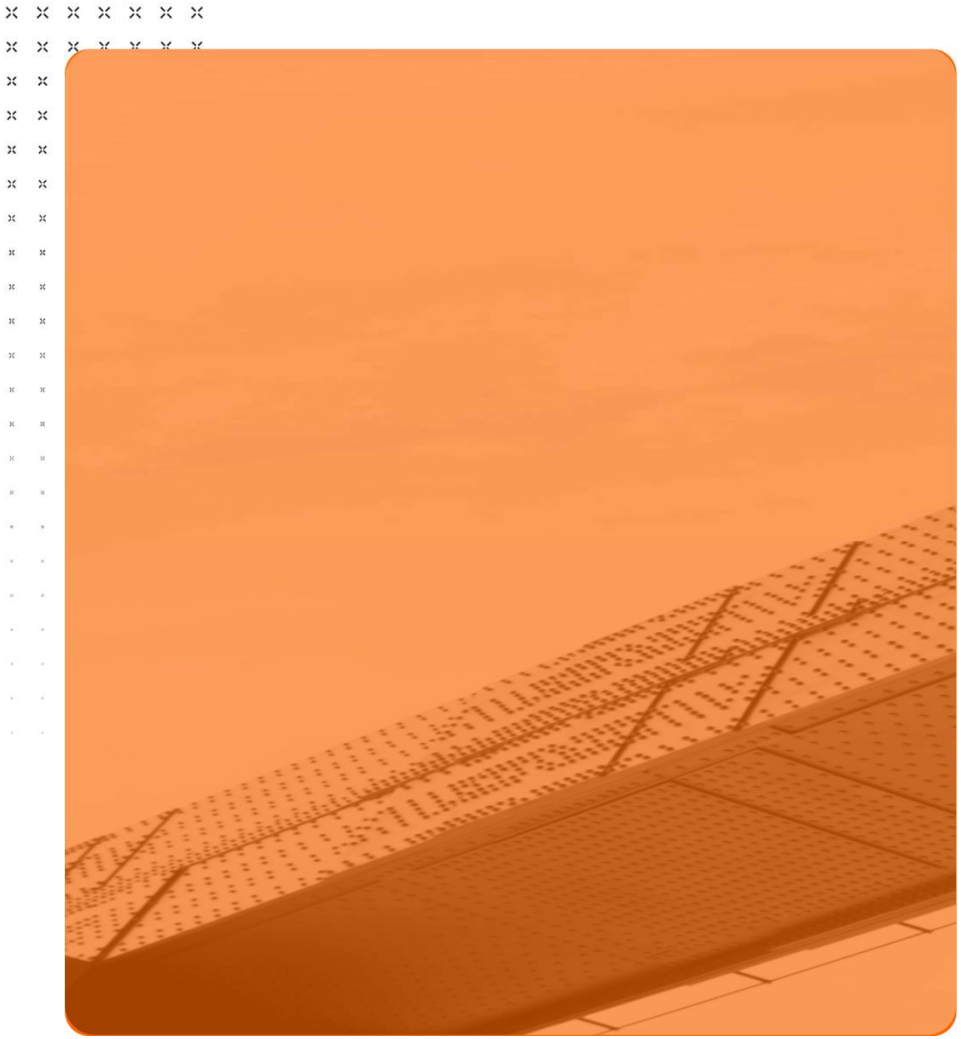
Scope guardrails

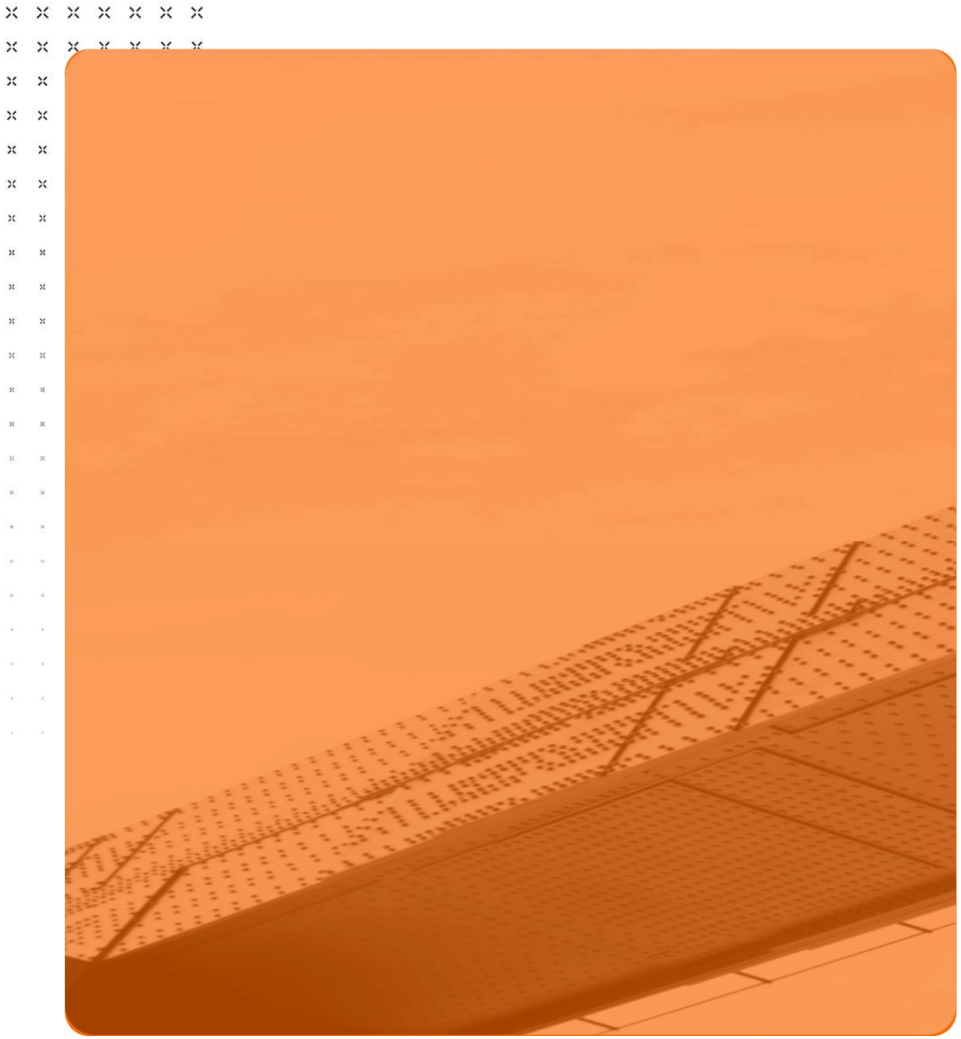
What's included

- Audit of controls and processes via screenshare/interview
- Risk findings and a remediation recommendations report
- Ongoing risk mitigation guidance from our advisors.

What's not included

- Implementing controls
- Acting as platform admins
- Continuous monitoring
- AI pentesting or prompt injection testing (yet)



Services Alignment

- Natural next steps (or steps to take in parallel with these assessments):
  - AI security awareness training
  - Vendor Risk Assessment
  - AI policy development (dedicated AI policies are on the way)
  - AI-focused tabletop exercises
  - Phishing Campaigns
  - CRA and Cloud Assessments